BANQUE ALDERAN (ENTITÉ FICTIVE)

Politique de gestion des incidents liés aux TIC

Détection, classification, traitement et notification des incidents

Référence	POL-SEC-014
Version	2.3
Date d'effet	1er mars 2026
Propriétaire	Direction de la Sécurité des Systèmes d'Information (DSSI)
Approbation	Comité des risques opérationnels, 12 février 2026
Prochaine revue	Février 2027
Classification	Interne

Avertissement : la Banque Alderan n'existe pas. Ce document a été créé pour tester un outil d'analyse documentaire. Il ne constitue ni un modèle de politique ni un avis juridique.

1. Objet et champ d'application

La présente politique définit le dispositif de gestion des incidents affectant les technologies de l'information et de la communication (TIC) de la Banque Alderan. Elle vise à limiter leur impact sur les fonctions critiques et à rétablir le service dans les meilleurs délais.

Elle s'applique à toutes les entités, à tous les collaborateurs et à tous les systèmes d'information de la Banque, y compris les environnements exploités pour son compte par des prestataires.

2. Définitions

- **Incident TIC :** événement, non planifié, qui compromet la sécurité des réseaux et des systèmes d'information et a un effet négatif sur la disponibilité, l'authenticité, l'intégrité ou la confidentialité des données ou des services.
- **Incident majeur :** incident TIC classé comme tel selon les critères de la section 5.
- **Cellule de crise :** équipe réunie par le RSSI pour piloter le traitement d'un incident majeur.

3. Rôles et responsabilités

Acteur	Responsabilités
Centre opérationnel de sécurité (SOC)	Surveiller les systèmes 24 h/24 et 7 j/7, détecter les événements, ouvrir et qualifier les alertes.
RSSI	Coordonner le traitement, proposer la classification et activer la cellule de crise.
Direction de la conformité	Préparer et transmettre les notifications à l'autorité compétente.
Directions métiers	Évaluer l'impact sur leurs activités et appliquer les mesures de continuité.
Direction des risques opérationnels	Contrôler l'application de la politique et suivre les plans d'action.

4. Détection et enregistrement

Le SOC met en œuvre des mécanismes de détection et des seuils d'alerte. Tout collaborateur signale sans délai un événement suspect au guichet de sécurité, par téléphone ou via l'outil de tickets.

Les incidents classés majeurs sont enregistrés dans le registre central des incidents, avec leur date de détection, leurs impacts, les actions menées et leur date de clôture. Les autres événements sont traités dans l'outil de tickets et ne sont pas repris dans ce registre.

5. Classification

Le RSSI évalue chaque incident dans un délai de 8 heures après sa détection. Un incident est classé majeur lorsqu'au moins l'une des conditions suivantes est remplie :

- **Clients touchés :** plus de 10 % des clients actifs sont affectés.
- **Durée :** l'indisponibilité d'un service dépasse 4 heures consécutives.

La classification peut être revue pendant le traitement si de nouveaux éléments le justifient. Toute décision de reclassement est motivée et tracée.

6. Traitement des incidents

- **Endiguement :** isoler les systèmes touchés et préserver les preuves utiles à l'analyse.
- **Rétablissement :** activer les plans de continuité et les sauvegardes pour restaurer les fonctions touchées.
- **Escalade :** réunir la cellule de crise dans l'heure suivant la classification en incident majeur.
- **Communication interne :** informer les équipes concernées par les canaux de crise.

7. Notification à l'autorité compétente

La Direction de la conformité notifie les incidents majeurs à l'autorité compétente selon les échéances ci-dessous, à partir des informations fournies par le RSSI.

Document	Échéance	Contenu principal
Notification initiale	Dans les 48 heures suivant la classification	Nature de l'incident, premiers impacts et services touchés
Rapport intermédiaire	À la résolution de l'incident	État du traitement, impacts actualisés et mesures prises
Rapport final	Dans les 3 mois suivant la résolution	Causes profondes, impact total et actions correctives

Une cybermenace importante peut être notifiée à titre volontaire lorsque la Direction de la conformité et le RSSI estiment qu'elle présente un intérêt pour le système financier, ses utilisateurs ou ses clients.

8. Information de la direction

Le RSSI présente chaque année au Comité des risques opérationnels un bilan des incidents majeurs : nombre, impacts, réponses apportées et contrôles renforcés. L'organe de direction reçoit une synthèse de ce bilan dans le rapport annuel sur les risques.

9. Prestataires tiers de services TIC

Les prestataires signalent à la Banque les incidents qui affectent les services fournis, selon les modalités et les délais prévus à l'annexe C des contrats concernés. Cette annexe est conservée par la Direction des achats et n'est pas reproduite dans la présente politique.

10. Analyse post-incident

Après chaque incident majeur ayant perturbé une activité essentielle, le RSSI organise une revue dans un délai de 20 jours ouvrés après la clôture. Elle établit les causes profondes, examine la qualité de la réponse et détermine les améliorations à apporter aux processus et aux contrôles. La Direction des risques opérationnels suit les actions qui en découlent jusqu'à leur achèvement.

11. Revue de la politique

La DSSI revoit cette politique au moins une fois par an, ainsi qu'après tout incident majeur révélant une insuffisance du dispositif.